People naturally share resources and delegate access to others to achieve their goals, so an API security solution should make this simple and secure; otherwise, your users will find insecure ways to do it anyway. In this chapter, you'll implement capability-based access control techniques that enable secure sharing by taking the principle of least authority (POLA) to its logical conclusion and allowing fine-grained control over access to individual resources. Along the way, you'll see how capabilities prevent a general category of attacks against APIs known as *confused deputy* attacks.

> **DEFINITION** A ***confused deputy attack*** occurs when a component of a system with elevated privileges can be tricked by an attacker into carrying out actions that the attacker themselves would not be allowed to perform. The CSRF attacks of chapter 4 are a classic example of a confused deputy attack, where the web browser is tricked into carrying out the attacker's requests using the victim's session cookie.

9.1 Capability-based security

A ***capability*** is an unforgeable reference to an object or resource together with a set of permissions to access that resource. To illustrate how capability-based security differs from identity-based security, consider the following two ways to copy a file on UNIX[34] systems:

- `cp a.txt b.txt`
- `cat <a.txt >b.txt`